HackMatrix ’ 26: Research Audit and Selection-Ready Project Plan

Executive brief

Recommendation: build PhishShift, a leakage-resistant evaluation and analyst prototype for phishing-URL models that tests generalization across source, time and registrable-domain groups. Do not pitch it as “a more accurate AI phishing detector.” Its contribution is to show, with controlled baselines, how reported detection quality changes when near-duplicate URLs, domains, campaigns and source-specific signals can no longer leak between train and test. Add a small, explainable lookalike-domain feature set and a calibrated “review / abstain” state, then compare against a character n-gram baseline and a rule-only dnstwist-style candidate generator. Existing studies establish URL classifiers and typosquatting tools; this project’s defensible claim is a careful, reproducible transfer evaluation—not a new classifier.

TrustPulse is not the top recommendation in its original form. CT-plus-passive-DNS phishing prediction, CT-only phishing pipelines, certificate anomaly models, provenance scoring and early-warning work already exist. A patent is unusually close to generic CT-time, issuer/certificate, lexical and passive-DNS phishing scoring. Historical passive DNS also presents a material access and licensing risk. TrustPulse can remain a later extension if the team narrows it to auditable evidence quality under missing or stale observations and confirms data access first. (1) (3) (4) (5) (18)

The recommendation is conditional on one early gate: verify that the exact public datasets and versions the team intends to compare are legally usable and include enough source, domain or time metadata for a defensible split. If that gate fails, pivot to **ClaimScope**, a small evidence-lineage and contradiction-review prototype for public threat reports. Neither project is guaranteed to be selected.

1. Problem and scope

The original project name, “AI-Powered Web Threat Detection & Digital Trust Intelligence,” spans at least six different tasks: URL classification, lookalike detection, visual impersonation, certificate monitoring, domain/infrastructure relationship analysis and threat-intelligence curation. These tasks use different labels and data. “Phishing,” “malware distribution,” “certificate misissuance,” “a suspicious certificate,” “a lookalike domain,” and “AI-generated email” are not interchangeable target classes. A system that merges them into one risk number without defining the prediction target is hard to evaluate and easy to overclaim.

A credible student project should choose one decision with a measurable outcome. For PhishShift, the question is: **How much do URL/domain phishing model results change when evaluation moves from a random row split to source-, time- and registrable-domain-separated tests, and can a small set of interpretable lookalike features improve useful recall at a fixed review budget?** The question is bounded, practical and open to a negative result.

The project will not promise to identify all phishing, predict actual victim harm, infer domain ownership, or prove that a site is benign because it does not appear in a feed. It will measure the model’s

performance on named dataset snapshots with an explicit label policy. Any user-facing output should say “known phishing,” “model assessment,” “lookalike candidate,” or “insufficient evidence,” rather than “safe.”

2. Archive audit

The uploaded outer ZIP contains two nested ZIP archives, five standalone research PDFs and the prior Markdown report. The two nested archives contain 40 PDFs. The complete manifest therefore lists **49 files** when the outer ZIP is counted: 45 PDFs, the original Markdown, two nested ZIPs and the outer ZIP. The machine-readable inventory includes paths, file types, byte sizes, PDF page counts, SHA-256 hashes and relevance classifications: complete archive inventory.

All 45 PDFs were extracted and had readable first-page text. No PDF failed the text extraction checks. Figure graphics, formula glyphs and some visually embedded table content do not always survive text extraction, so the report does not claim that every chart was machine-readable. A binary SHA-256 check found no exact duplicate PDF files.

Seven PDFs are directly relevant or materially adjacent. Five were standalone: (1) *Finding Phish in a Haystack: A Pipeline for Phishing Classification on Certificate Transparency Logs* (ARES 2021); (2) *SoK: SCT Auditing in Certificate Transparency* (adjacent, focused on privacy-preserving SCT auditing rather than phishing classification); (3) *Anomaly Detection in Certificate Transparency Logs* (2024); (4) *Content-Agnostic Detection of Phishing Domains using Certificate Transparency and Passive DNS* (RAID 2022); and (5) *Phishing or Not Phishing? A Survey on the Detection of Phishing Websites* (IEEE Access 2023). One PDF in the 2023 ScienceDirect batch is a systematic review of phishing website detection. One PDF in the 2024 batch is *Unmasking phishers: ML for malicious certificate detection*. These are summarized in the relevant-paper inventory below.

The other 38 PDFs were excluded after title/abstract screening. In the 2023 batch, 17 of 18 papers are about other topics such as general deep-learning/optimization methods, unrelated biomedical or industrial applications, IoT access control, or web vulnerability analysis. Some are adjacent by vocabulary—“trust,” “web,” or “machine learning”—but do not study phishing, public-key infrastructure, certificates, threat intelligence or the proposed evaluation problem. In the 2024 industrial-engineering batch, 21 of 22 files are outside the scope, including industrial/supply-chain/healthcare studies and non-research front matter. The full filenames and reasons are recorded in the CSV rather than reproducing a long unrelated-paper list here.

Audit findings on the original report

The report at original Markdown research report is a valuable starting synthesis, but its own evidence trail is not included in the ZIP. It says it synthesizes 13 stream reports under `/home/ubuntu/research-streams/`; that supporting directory was not present in the uploaded archive or workspace checked during the audit. The claim that 13 stream reports were completed is therefore not verifiable from the delivered research package.

Two bibliographic errors are material. The report calls DOI 10.$^{1145}/_{3545948}$.3545958 “Phishious” and gives a shortened/inaccurate title; the ACM record identifies the paper as *Content-Agnostic Detection of*

Phishing Domains using Certificate Transparency and Passive DNS. It also cites arXiv:2405.05206 as MANTIS/hosting-infrastructure graph work. The actual title is *Anomaly Detection in Certificate Transparency Logs*, by Richard Ostertág and Martin Stanek, and it applies Isolation Forest to certificate attributes. MANTIS is a different 2025 paper at arXiv:2502.09788. (1) (2) (5)

There are redundant citations and claims: the original references 27 and 87 point to the same cross-dataset URL study, and references 70 and 86 point to MISP. The report also makes a broad novelty statement that no sampled implementation joins provenance, contradictions, missingness and calibrated decisions. This is an observation about the sampled code and sources, not an exhaustive prior-art result. STIX provenance fields, provenance-aware cyber knowledge graphs, IoC graph scoring and newer claim-evidence lineage work make “provenance” or “corroboration” alone poor novelty claims. (6) (7) (8) (9)

The report does not cite several of the most relevant papers physically included in the archive: the 2021 CT phishing pipeline, the 2024 CT anomaly paper, the 2024 malicious-certificate paper, the privacy-oriented SCT auditing paper and the 2023 phishing survey. The prior report also develops five candidate concepts but does not provide the three-concept weighted comparison the mission requests. Its 18-gap matrix is useful for ideation, but the gap claims were not ranked by demonstrated novelty or by data feasibility.

The eMudhra discussion should also be kept narrower than the original report’s strongest wording. The Mozilla incident record supports a researcher’s proof of control over affected intermediate private keys, Mozilla’s independent recovery, and emergency trust-store action. It does not establish that public telemetry could have predicted the compromise, that targeted interception occurred before disclosure, or that code-signing abuse happened. Claims about the precise ceremony/script root cause should be attributed to eMudhra unless independently confirmed. (10)

3. Research landscape and prior art

URL and domain detection

URL detection is mature. Common families include lexical/character models, domain or registration metadata, DNS/reputation features, page-content features and visual similarity. Character n-gram TF-IDF plus logistic regression is an important low-cost baseline; URL spelling and domain metadata can be added as separate feature families. Published results on one curated or random-split dataset do not establish transfer to later samples, unseen domains or different sources. A 2024 cross-dataset study explicitly investigates whether phishing URL features remain trustworthy across diverse datasets, supporting evaluation under source shift rather than another random split. (11)

Domain lookalike generation is also available as an open-source capability. dnstwist produces permutations and can check IDN/homograph or similarity patterns. It is a candidate generator, not a ground-truth phishing classifier: a similar domain can be benign, parked, redirected, advertising-supported or malicious. Compare the rule-only output separately from a learned model. (12)

CT, certificates and early warning

The archive contains three especially important findings for evaluating TrustPulse. First, the 2021 CT pipeline already classifies phishing certificates on CT logs, describes real-time processing and publishes research code/data. Its authors report 117 detected malicious certificates and 2,251 false positives during a week-long evaluation at a fixed 10^{-4} false-positive rate for the best classifier; they explicitly describe label incompleteness, manual verification burdens, wildcard domains, compromised hosting and the absence of a complete ground truth. This is evidence that CT-only early-warning pipelines already exist, not proof that a new system can deliver a useful alert rate. (3)

Second, the 2022 RAID study combines CT, passive DNS and lexical or temporal domain evidence. It reports 0.3% false-positive rate, 98% precision and 90% recall under its study's evaluation, and says it predicted phishing domains days before VirusTotal discovery. Those are author-reported results for a particular dataset, threshold and period; they are not a contemporary operating guarantee. It is very close prior art for the original TrustPulse signal combination. (1)

Third, the 2024 *Unmasking phishers* paper combines certificate, domain and BiLSTM-derived features. Its reported certificate-only random-forest F1 is 0.77, while its richer model reports F1 0.89. It also performs a five-month time-based evaluation with monthly updates and reports mean F1 0.88. The dataset and protocol are paper-specific and rely on Tranco and PhishTank-derived labels; the result means time-aware certificate phishing classification is already published, not that the reported model will generalize to a new deployment. (4)

Certificate anomaly detection is not equivalent to abuse detection. The 2024 Isolation Forest study samples 120,000 CT records and finds statistically unusual certificate profiles, including operational/test/cloud infrastructure patterns. It has no maliciousness ground truth. Its authors explicitly distinguish anomalous from malicious certificates. A UI must therefore call the output "unusual relative to this baseline," not "fraudulent." (5)

Certificate Transparency is a public audit and monitoring mechanism, not a benignity label. RFC 9162 specifies monitors and Merkle-based auditing, but does not itself prevent misissuance or define the incident-response decision. CT logs may be incomplete from a monitor's vantage point. A CT event can be useful evidence of issuance, but it cannot by itself establish that the certificate is deployed, malicious or trusted by every client. (13) (14)

DNS, hosting graphs and registration-time signals

Passive-DNS/domain graphs and registration-time prediction are established areas. EXPOSURE and later graph work use DNS behavior and shared infrastructure; PREDATOR established registration-time abuse prediction; MANTIS and Blocklist-Forecast address malicious-domain prediction via low-reputation hosting or malicious infrastructure. Shared hosting, CDNs, compromised benign websites and registry/provider bias are persistent confounders. Generic "combine a graph with a classifier" is not a defensible novelty claim. (15) (2) (16) (17)

There is also a direct patent overlap. US11546377B2, *Phishing domain detection systems and methods*, describes CT-derived time, issuer and certificate features combined with passive-DNS and lexical signals for phishing-domain scoring. This patent record materially weakens any pitch that the generic CT-plus-DNS scoring architecture is itself original. This report is not a legal opinion: patent scope,

status, enforceability and freedom to operate require specialist review. The practical selection implication is to avoid that broad novelty claim and to choose an evaluation or data-quality contribution instead. (18)

Historical passive-DNS access is a feasibility gate, not an assumption. Spamhaus offers paid products and a time-limited trial; CIRCL's documented service is restricted to trusted partners; Rapid7 describes licensing or sponsorship requirements for some access. Censys research data similarly requires approval and imposes use/redistribution conditions. A project should not depend on these datasets until the team has obtained access and verified the terms. RDAP is a present lookup protocol, not a complete historical registry archive. (19) (20) (21)

Provenance, uncertainty and CTI

Evidence lineage, confidence and correlation are not new on their own. STIX 2.1 provides creator references, confidence, sightings, opinions and data markings. STIX confidence is the producing source's confidence, not a calibrated probability that a claim is true. NIST guidance notes that source attribution matters because repeated reporting may not be independent corroboration. Provenance-aware cyber knowledge graphs and STIX graph-based IoC scoring predate this project. A 2026 TRACE-CTI preprint directly retains claim evidence, source provenance, contradiction and corroboration metadata; it warns that duplicated support does not prove statistical independence. (6) (7) (8) (9)

Calibration and abstention are valuable evaluation tools, but they are established methods. A system should not call an output "calibrated" unless it measures calibration on an independent, chronologically prior validation set and reports the resulting reliability. A score is also not a finding. The useful research question is narrower: does explicit evidence availability, source-family dependence, contradiction and missingness handling change error, review burden or time-to-detection under a defined test? (9) (22)

Visual and multimodal methods

Visual phishing detectors such as VisualPhishNet and Phishpedia already use page appearance or logo-to-brand similarity. A 2025 USENIX study evaluates visual-similarity systems on a large real-world corpus and adversarial manipulations, reporting a degradation from curated data and sensitivity to visible changes. That supports safe, controlled robustness testing; it does not make a logo matcher novel. Live rendering brings safety, privacy and reproducibility problems: browser version, viewport, locale, redirects, load timing and takedowns alter screenshots. For PhishShift, page rendering is out of MVP scope. (23) (24) (25)

AI-generated phishing is adjacent, not a synonym for malicious-domain detection. A paper using 865 generated emails studies text authorship/style, not whether a URL, domain or website is malicious. It is not evidence for a reliable detector of AI-generated phishing websites. Do not spend the MVP's time on an "AI-written" classifier unless the research question is specifically about email content and suitable cross-generator data are available. (26)

Coverage of the 18 requested research domains

Domain	Finding that affects project choice
Phishing website detection	Mature URL, content and visual families; choose one target and do not treat their labels as interchangeable. (3) (24) (25) (41)
Malicious URL detection	Character and lexical models are strong baselines, but transfer across source and domain is a measurement problem. (11) (35)
Domain impersonation / typosquatting	Lookalike generation is available; similarity produces candidates, not a phishing verdict. (12)
Visual website identity	Logo/screenshot methods exist and can lose performance under real-world or adversarial conditions. Rendering is high-risk and deferred. (23) (24) (25)
TLS certificate validation	Linting checks defined X.509/policy properties; it does not determine that a website is benign or that domain validation was correct. (44)
Certificate Transparency monitoring	CT is public issuance observability and audit, not a safety label; monitoring coverage and log integrity matter. (13) (14)
Certificate Authority compromise	Public incident records support retrospective key-compromise response analysis, not a claim that public logs predicted the specific 2026 event. (10)
Certificate anomaly detection	Isolation Forest on CT features is prior art; statistical anomaly is not maliciousness. (5)
DNS / passive DNS	Behavioral and graph analysis are established, but history is often access-gated and provider-vantage-specific. (15) (19) (20) (21)
Domain registration intelligence	PREDATOR establishes registration-time abuse prediction; modern point-in-time registration logs remain an access risk. (16)
Hosting relationships	Shared hosting and CDNs confound maliciousness; low-reputation hosting graphs and blocklist forecasts already exist. (2) (17)
Graph-based threat intelligence	STIX/MISP/OpenCTI and hosting-graph systems exist; visualization alone is not detection. (2) (6) (7) (17) (30) (31)
Temporal/predictive detection	CT lead time and certificate-model time splits are established; clock definitions and label availability still need careful testing. (1) (3) (4)
AI-generated phishing	A small generated-email study is not evidence of a robust AI-phishing website detector. (26)

Domain	Finding that affects project choice
Explainable cybersecurity AI	Feature attributions and evidence spans are useful diagnostics, but explanations need faithfulness/stability testing; explanation alone does not establish a prediction. (11) (22)
Collaborative threat intelligence	STIX and MISP support structured exchange; source independence and claim lineage remain important. (6) (7) (8)
Privacy-preserving security intelligence	Federated methods exist; they do not automatically prevent leakage, poisoning or membership attacks. They are not required for PhishShift. (7) (42)
Web security configuration assessment	Header/TLS hardening checks measure configuration posture, not phishing intent. Keep this as a separate audit task rather than a phishing feature label. (43) (44)

4. Commercial products and common hackathon patterns

The following is a capability comparison based on public documentation, not a benchmark of proprietary detection accuracy.

Product or project pattern	Existing capability	Likely demo a team might show — prediction only	Why that alone may not stand out	PhishShift alternative
Google Safe Browsing / Web Risk	URL threat-list and reputation lookup.	Paste a URL and display a known-bad / no-match response.	A lookup wrapper is easy to build; no-match does not prove benign.	Evaluate model behavior on dated snapshots and keep API verdict separate from labels. (27)
VirusTotal / Google Threat Intelligence	Aggregates engine verdicts and domain/IP/certificate context.	Show engine count, relations or a verdict summary.	Engine results can be correlated; quota/service output is not independent ground truth.	Use authorized output only as an attributed comparator, not as truth. (28)
urlscan.io	Records requests, redirects, TLS details and screenshots.	Submit a URL and show a screenshot or scan report.	Scanning is established; public submissions can expose the URL and page content.	Avoid live crawling in MVP; evaluate model transfer and show a static case card. (29)
MISP / OpenCTI	Structured TI storage, correlation and graph pivoting.	Display an IOC graph or connected incident reports.	A graph dashboard is not a graph detector or new evidence method.	Make the split protocol and error analysis the technical contribution. (6) (30) (31)
CT watchlist / certificate dashboard	Monitors public certificate issuance for domains or patterns.	Stream a new certificate alert and display subject/SAN.	CT monitoring is established and a certificate is not a phishing verdict.	Keep CT out of the required PhishShift path; use it only in a later extension. (13) (14)
Typical URL classifier	Trains on a static dataset and returns a score.	Enter URL, show a probability or	Random row splits and source leakage	Compare random and domain/source-

Product or project pattern	Existing capability	Likely demo a team might show — prediction only	Why that alone may not stand out	PhishShift alternative
		green/red badge.	can overstate performance.	held-out tests, with a fixed alert budget.
AI security chatbot / multi-API aggregator	Summarizes vendor answers or composes several APIs.	Ask “is this safe?” and display a generated answer.	Polished language may hide unsupported provenance and model uncertainty.	Expose the dataset label, feature evidence, decision limit and failure cases.
Browser extension	Flags visited URLs or displays a trust score.	Navigate to a site and show an in-browser warning.	Browser integration is costly; one API behind a UI is not a research contribution.	Defer deployment and first establish a reproducible evaluation.

No official HackMatrix ’26 rules, rubric, gallery or confirmed competitor submissions were verified in the accessible research. The matrix below therefore treats competitor demos as **predictions**, based on the user-provided archetypes and documented products, not as actual entrant submissions. The simplest ways these projects fail to stand out are already implicit in the evidence: using a known API as the contribution, treating feed absence as benign, evaluating on random rows, or showing an uncalibrated score without a useful baseline.

5. Candidate research gaps

The ranking below separates “a useful under-tested question” from “a new method.” None should be described as never done.

Rank	Candidate gap	Novelty potential	Feasibility	Why it matters and main limitation
1	Source-, time- and registrable-domain-separated evaluation of phishing URL models.	Medium	Medium–high	Directly tests whether familiar benchmark scores survive source shift and entity leakage. Dataset timestamps and license/version must be checked.
2	Lookalike/IDN candidate generation evaluated separately from maliciousness classification.	Medium	High	Separates “looks like a brand” from “confirmed phishing” and permits a strong rule baseline. Similarity alone creates benign false positives.
3	Source-lineage and dependence-aware corroboration under copied or contradictory CTI claims.	Medium	Medium–high	STIX, provenance scoring and TRACE-CTI are close prior art; a small independent controlled evaluation is a possible contribution.
4	CT/DNS alerts with explicit freshness, missingness and coverage.	Low–medium	Medium–low	A plausible robustness extension, but generic CT+pDNS detection is close prior art and pDNS access is gated.
5	Visual capture failure and redirect-following ablation for phishing pages.	Medium	Medium–low	Real-world rendering limitations matter; safe data, old papers and crawling load complicate execution.
6	Registration-time domain-abuse forecasting from point-in-time RDAP or registry logs.	Medium	Low	PREDATOR and newer registration research establish the problem; dependable historical, redistributable records were not verified.
7	AI-generated phishing email detection robust to new generators and languages.	Low–medium	Medium	Available corpus evidence is narrow and generator-specific; authorship is not the same as malicious intent.

Selected gap: the first. Its originality is an empirical protocol and dataset analysis, not a new classifier. The experiment should quantify the gap between an easy random split and a stricter test; identify which

feature groups transfer; and report whether a lookalike candidate step improves recall at an alert limit without causing an unacceptable false-positive burden.

6. Critical evaluation of TrustPulse

What already exists: CT-only phishing pipelines, CT-plus-passive-DNS prediction, certificate anomaly methods, registration-time prediction, infrastructure graphs, CTI provenance, STIX confidence and explicit claim-evidence lineage. The direct patent overlap makes a generic CT+pDNS score particularly weak as a novelty claim. (1) (3) (5) (6) (9) (2) (16) (18)

What the original proposal gets right: point-in-time data availability is a real evaluation issue. Later labels cannot be used as if they were known when a model made an alert. Feed assertions, model assessments and verified findings should remain distinct. CT, DNS and web observations are incomplete, and shared hosting creates ambiguity. A replay timeline and fixed alert budget could make the experiment easier to inspect.

What remains unproven: no reviewed result shows that adding a typed evidence ledger or calibration to existing CT+pDNS work improves real-world lead time or analyst outcomes. “Provenance-aware,” “uncertainty-calibrated” and “contradiction-aware” are design descriptions, not measured benefits. Temporal evaluation has prior art, including the five-month 2024 certificate-phishing test; it cannot be claimed as new by itself. Calibration alone is not innovation. (1) (4) (6) (9)

Can the original system be built? A small replay prototype can be built. A global, current, historical trust graph that combines CT, passive DNS, RDAP, visual identity, redirections, independent labels and calibrated outcomes is not a reliable hackathon commitment. Public CT events do not solve historical DNS access or label timing. The MVP would have to omit most proposed modalities, which undercuts the broad architecture claim. The project should establish data access and label semantics before choosing a model.

Could it outperform simple baselines? Unknown. The correct answer is a pre-registered hypothesis, not a promised win. Compare against a URL-only character model, a certificate-only model if certificate labels are available, a rule-only lookalike generator, and any authorized external reputation lookup. Evaluate at the same test cutoff and alert budget. If TrustPulse only improves a polished UI while metrics remain unchanged, its central claim fails.

Decision: retain TrustPulse as a later, higher-risk concept or as a limited demo layer, but do not make it the selected research contribution. If the team insists on TrustPulse, reframe it as an **evidence-quality audit** under stale/missing/conflicting signals, not a novel CT/pDNS phishing detector, and make passive-DNS access a go/no-go condition.

7. Three project concepts

Concept A — PhishShift: source- and domain-shift evaluation for phishing URLs

Required field	Concept definition
1. Project name	**PhishShift — Leakage-resistant evaluation of phishing URL detection**
2. Problem statement	Static/random-split URL metrics may not predict performance on later or unseen registrable domains. Quantify how performance changes under stronger source/entity splits.
3. Target user	Security researchers, student SOC teams and defenders who need to decide whether a URL detector is safe to use at a chosen alert volume.
4. Existing solutions	URL lexical classifiers, phishing reputation feeds, dnstwist-style lookalike generation, research datasets and commercial URL lookups.
5. Verified research gap	Cross-dataset feature trust and dataset dependence are documented. The specific contribution is a transparent comparison with domain/source separation and label semantics, not a claim that URL transfer has never been studied. (11)
6. Technical innovation	A point-in-time/source-aware evaluation harness with registrable-domain grouping, exact/near-duplicate detection, separate “lookalike” and “confirmed phishing” outputs, and threshold selection at a fixed analyst-review budget.
7. Difference from common projects	Not just another classifier or API wrapper. The demo shows how random-split results differ from domain/source-separated results and surfaces evidence and uncertainty for individual cases.
8. AI/ML methodology	Baseline A: hostname/URL character 2–5-gram TF-IDF + logistic regression. Baseline B: normalized lexical/domain features + Random Forest or LightGBM. Baseline C: dnstwist-style deterministic permutation/IDN similarity, reported separately. Calibration is fitted only on validation data; abstention is optional and measured.
9. Required datasets	One verified phishing source with dated records and terms; a separate benign or unlabeled cohort; optionally two public datasets for cross-source testing. PhishTank and UCI are candidates, subject to date/version/terms audit. Tranco is a popularity proxy, not a benign truth set. URLhaus is malware distribution, not phishing. (32) (33) (34) (35) (36)
10. System architecture	Immutable dataset manifest → safe URL normalizer/IDNA parser → deduplication and domain grouper → split generator → baselines and

Required field	Concept definition
	candidate generator → validation-only calibration/threshold → results API and analyst UI.
11. Experimental validation	Random split is shown only as an optimism comparison. Main results use source-separated and domain-grouped tests; chronological test only if trustworthy timestamps are present. Report PR-AUC, precision/recall/F1, FPR, precision/recall at fixed review budget, calibration, class/source coverage and error breakdown.
12. Expected prototype	Offline web application with dataset/version selector, model comparison, a URL analysis card, split/duplicate audit and a reproducible report export. No live phishing page needs to be fetched.
13. Implementation difficulty	Medium. The classifiers are simple; data cleaning, license/provenance, deduplication and valid splits are the difficult parts.
14. Estimated timeline	8–12 focused days for a small student team, **only if** usable data are available at start; otherwise the timeline extends. Days 1–2 are a hard data and license gate.
15. Main risks	Source labels are imperfect, dated feed snapshots may not exist, static datasets may lack collection time, IDN/domain parsing may be inconsistent, and a stricter test may have too few examples.
16. Technical differentiation	Separates candidate resemblance, phishing labels and unlabelled absence; identifies leakage; makes alert-budget choices visible; preserves input and source lineage. No new algorithm claim.
17. Demonstration potential	High if it shows a model appearing strong on a random split but changing on a domain/source-held-out test, plus a case-level explanation and fixed-budget comparison. Only show actual measured results from the frozen dataset.
18. Selection-oriented strengths	Clear problem, reproducible experiment, low infrastructure cost, recognizable security use, and a visible technical lesson beyond “AI gives a score.”
19. Evidence supporting novelty	Published cross-dataset research establishes the importance of transfer; URL and lookalike baselines are implementable; the archive establishes the maturity of existing detection methods. The value is the named benchmark question and reproducibility, not first detection. (11) (12)

Required field	Concept definition
20. Evidence contradicting novelty	URL ML and typo generation are common and established. A judge may see this as evaluation rather than invention. The team must make the protocol, data audit, source-shift comparison and actionable error analysis the actual technical contribution. (11) (12)

Concept B — TrustPulse Lite: incomplete-evidence CT domain triage

Required field	Concept definition
1. Project name	**TrustPulse Lite — Evidence-quality replay for CT domain alerts**
2. Problem statement	A CT/DNS-derived suspicious signal can be stale, incomplete or shared by benign hosts, and alert quality is often not evaluated at a defined time and workload.
3. Target user	Domain owners, small SOC teams and CT monitoring researchers.
4. Existing solutions	CT monitors, CT+pDNS phishing papers, certificate-lint tools, vendor reputation services and commercial passive-DNS products.
5. Verified research gap	No exhaustive proof of an empty space. A defensible small question is whether explicit freshness/coverage/missingness displays improve triage under incomplete evidence compared with a flat rule score. Generic CT+pDNS phishing scoring is prior art and has direct patent overlap. (1) (3) (18)
6. Technical innovation	A replayable event ledger that distinguishes certificate observation, DNS observation, feed assertion and independent later outcome; score evidence coverage and abstain when core observations are missing. Treat this as an evaluation contribution.
7. Difference from common projects	Not another CT regex or reputation dashboard if it tests and visualizes the effect of missing/stale evidence at a fixed alert burden. Without that experiment, it is a common monitor.
8. AI/ML methodology	Baseline certificate/lexical rules; simple calibrated logistic/tree model only if labels support it; test selective risk/coverage and missing-signal ablations. Do not fit an unsupervised anomaly score and call it maliciousness.
9. Required datasets	Public CT logs; independently timestamped phishing labels; optional passive DNS, only after access/retention terms are confirmed; safe frozen controls. CertStream is not a completeness-guaranteed CT census. (13) (19)
10. System architecture	CT/log source → normalizer → event ledger → point-in-time feature builder → rule/model baselines → validation-only calibration/abstain policy → evidence replay UI.
11. Experimental validation	Future-time and domain/infrastructure grouped split; missing/stale signal perturbations; compare certificate-only to certificate+available DNS; report precision/recall/F1, FPR, alert workload, label lead-time and coverage.

Required field	Concept definition
12. Expected prototype	Frozen replay with a CT event, later independent label, evidence timestamps, missingness and reason-coded alert/abstain.
13. Implementation difficulty	Medium-high because history, labels and passive DNS are the bottleneck.
14. Estimated timeline	12–18 focused days, conditional on already-approved data access; without it, scope must be reduced to CT-only or changed.
15. Main risks	Close prior art/patent overlap, incomplete monitor coverage, pDNS cost, weak labels, shared hosting and overclaiming prediction.
16. Technical differentiation	Operationalizes a controlled missingness/freshness experiment, not new CT/pDNS feature engineering.
17. Demonstration potential	Very high: a replay clock, alert, contradictory/missing feed state, uncertainty and baseline comparison are easy to communicate.
18. Selection-oriented strengths	Strong visual story and direct connection to project title; can showcase PKI knowledge and evidence handling.
19. Evidence supporting novelty	CT monitoring, data leakage and feed-delay concerns make the problem valid; the specific incomplete-evidence experiment remains useful. (3) (13) (14)
20. Evidence contradicting novelty	The underlying detection combination, timing and certificate/DNS scoring already exist. A patent is close to generic feature combination; STIX and evidence-provenance work cover many proposed abstractions. (1) (6) (9) (18)

Concept C — ClaimScope: source-aware CTI claim and contradiction audit

Required field	Concept definition
1. Project name	**ClaimScope — Evidence lineage and conflict review for cyber threat claims**
2. Problem statement	Threat reports often repeat claims from upstream sources; a count of reports can look like corroboration even when the sources are dependent or disagree.
3. Target user	Threat-intelligence analysts, incident responders and cyber researchers.
4. Existing solutions	STIX/MISP/OpenCTI, provenance-aware knowledge graphs, IoC quality scoring and emerging claim-evidence extraction frameworks.
5. Verified research gap	A narrow test of source-family-aware corroboration and visible contradiction/abstention on a curated, manually reviewed corpus is defensible; provenance itself is established and TRACE-CTI is close recent prior art. (6) (7) (8) (9)
6. Technical innovation	Preserve exact evidence spans, publisher/date, upstream citation/source family, polarity and extractor version; compare naive source counts to source-cluster-aware corroboration and abstention.
7. Difference from common projects	Not a chatbot that summarizes threat reports. Every claim is linked to its source text and counterevidence; system exposes uncertainty and source dependence.
8. AI/ML methodology	Rule/LLM-assisted claim extraction with exact span retrieval; source-family clustering; simple source-aware scoring; human adjudication. LLM output must not replace evidence verification.
9. Required datasets	Small corpus of public CERT-In/CISA/vendor incident reports and advisories, with exact citations, timestamps and a two-rater annotated subset. Respect copyright, source terms and redistribution limits.
10. System architecture	Report ingestion → claim/span extraction → source lineage graph → contradiction and copied-source detection → reviewer UI → adjudicated export.
11. Experimental validation	Controlled duplicates, copied/syndicated reports and conflicting claims; compare majority source count with lineage-aware scoring; measure evidence-span correctness, contradiction recall, reviewer agreement, abstention and review time.

Required field	Concept definition
12. Expected prototype	An analyst can select a claim, see the exact supporting/contradictory passages, trace source relationships and accept/reject/abstain.
13. Implementation difficulty	Medium; manual annotation and source/dependency mapping are the largest effort.
14. Estimated timeline	8–12 focused days for a 60–100-claim pilot, plus annotation and review. Dataset size should follow team capacity, not a target in advance.
15. Main risks	Similar recent research exists, source independence is difficult to infer, LLM hallucination, annotation inconsistency and threat-reports' source terms.
16. Technical differentiation	An auditable evidence-graph and challenge-set evaluation, not general-purpose cyber "fact-checking."
17. Demonstration potential	High: duplicate sources collapse to one origin; an opposing dated report remains visible; unsupported claim triggers abstention.
18. Selection-oriented strengths	Feasible without paid pDNS or live malicious-site browsing; credible human-in-loop story and clear evidence trace.
19. Evidence supporting novelty	NIST stresses source attribution; provenance/CTI quality research shows a problem; explicit source-dependence and contradiction testing is practical. (7) (8)
20. Evidence contradicting novelty	STIX, provenance-aware CKGs, IoC graph scoring and TRACE-CTI are direct prior art. Do not claim the first evidence graph or first source-aware CTI system. (6) (8) (9)

8. Weighted selection scorecard

The user-supplied weights are used as provisional weights, not official HackMatrix criteria. Scores are 1–5, where 5 is strongest. Weighted total is `sum(score × criterion weight) ÷ 5`, giving a 100-point scale. Estimates are decision aids; a change of 0.3 in one criterion changes the score by only a few points. No official judging rubric or confirmed competitor entries were verified.

Concept	Problem 20%	Innovation 25%	Implementation 20%	Feasibility 15%	Demo 10%	Evidence 10%	Weighted total
PhishShift	4.0	3.5	4.2	3.7	4.2	4.2	**78.2/100**
TrustPulse Lite	4.4	2.8	3.5	2.7	4.8	4.2	**71.7/100**
ClaimScope	3.8	3.2	4.0	4.2	4.2	4.2	**76.6/100**

The lead is not decisive; estimates have at least ±4 points of uncertainty. PhishShift ranks first because it targets a real problem, can use comparatively simple baselines and can demonstrate a measurable protocol rather than relying on gated pDNS. Its innovation score is moderate because the algorithms are established. ClaimScope is the best fallback if dated phishing data cannot be cleared; its feasibility and demo are good, but recent evidence-lineage work makes its technical novelty moderate. TrustPulse has the strongest story and demo, but its novelty and data-access scores drop under the direct prior art and patent evidence.

Criterion score	PhishShift reasoning and uncertainty	TrustPulse Lite reasoning and uncertainty	ClaimScope reasoning and uncertainty
Problem understanding	**4.0.** Phishing URL detection is a clear, established problem, and cross-source leakage changes real deployment meaning. Uncertainty: the team must define one label and intended population. Improve by a preregistered target and source map. (11)	**4.4.** CT/DNS observations and trust degradation are relevant, and the original project directly fits. Uncertainty: public CT/DNS signals do not capture victim harm or prove maliciousness. Improve with one explicit outcome/horizon and verified independent labels. (1) (3)	**3.8.** CTI source dependence is a legitimate analyst problem. Uncertainty: impact may appear less direct than detection for a broad HackMatrix audience. Improve with an analyst task and measured review reduction. (7)
Technical innovation	**3.5.** Transfer/leakage-aware evaluation and separate lookalike candidate generation add rigor, but do not invent a classifier. Uncertainty: related cross-source methods exist. Improve with a genuinely new, reproducible dataset/protocol and a robust external holdout. (11) (12)	**2.8.** The proposed signals and fusion closely match research and patent claims. The remaining contribution is a narrow robustness/decision experiment. Improve only through evidence that the proposed missingness/coverage policy changes outcomes against strong baselines. (1) (18)	**3.2.** Source-lineage and contradiction evaluation are meaningful, but STIX, provenance graphs and TRACE-CTI overlap. Improve with controlled duplicate-source and conflict tests and a comparative human evaluation. (6) (8) (9)
Technical implementation	**4.2.** TF-IDF, logistic regression, tree models, normalization and grouped splits are tractable. Uncertainty: data cleaning and domain grouping take more effort than training. Improve with a frozen manifest and	**3.5.** Replay, event-time features and evidence UI are implementable; temporal model is not the hard part. Uncertainty: passive DNS and reliable labels may not be accessible. Improve by starting CT-only and making pDNS optional. (19) (20)	**4.0.** A claim graph, evidence-span view and adjudication workflow are technically manageable. Uncertainty: annotation and source-linking are labor-intensive. Improve with a small,

Criterion score	PhishShift reasoning and uncertainty	TrustPulse Lite reasoning and uncertainty	ClaimScope reasoning and uncertainty
	deterministic pipeline. (11) (16)		high-quality corpus and inter-rater agreement. (7) (9)
Feasibility / scalability	**3.7.** A small offline benchmark is feasible if dataset use and fields are confirmed; larger claims require more data. Uncertainty: temporal timestamps and license metadata may be absent. Improve with a day-two data gate and a preapproved fallback dataset. (32) (36)	**2.7.** Data scope and pDNS access materially constrain the full design. Uncertainty: access could be granted but is not guaranteed. Improve by securing written terms before build and sharply limiting the monitored cohort. (19) (20) (21)	**4.2.** Public reports can be collected without paid APIs, and a bounded corpus is practical. Uncertainty: source dependence is not always explicit in report citations. Improve through human annotation of lineage and conflict. (7)
Demonstration	**4.2.** A side-by-side split comparison and case-level explanation are understandable. Uncertainty: the effect may be smaller than expected. Improve by using one frozen, valid example and show honest error cases.	**4.8.** A replay timeline and uncertainty states are highly visual. Uncertainty: simulated events can look like fabricated performance. Improve by separating historical evidence, live observations and clearly marked simulation.	**4.2.** A traceable claim with a conflicting source is compelling. Uncertainty: can resemble a document chatbot. Improve by making source lineage, counterevidence and reviewer action visible.
Evidence / credibility	**4.2.** URL, lookalike and cross-dataset prior art are well established; public sources/datasets exist. Uncertainty: no experiment is reproduced yet. Improve through	**4.2.** Many strong prior papers and standards exist, but most directly contradict a first-combination claim. Uncertainty: scoped missing-evidence method needs more prior-art review. Improve by stating limits and publishing the	**4.2.** STIX/NIST, provenance and newer claim-evidence papers provide strong footing. Uncertainty: newest preprint work may narrow the gap. Improve by

Criterion score	PhishShift reasoning and uncertainty	TrustPulse Lite reasoning and uncertainty	ClaimScope reasoning and uncertainty
	primary-source audit, archived snapshot hashes and confidence intervals. (11) (12) (16)	benchmark protocol. (1) (3) (5) (18)	accurately positioning the experiment against TRACE-CTI. (6) (7) (8) (9)

9. Final recommendation and exact contribution

Build **PhishShift** if the data gate passes. Do not pitch it as “an AI that detects phishing better than everyone else.” The defensible statement is:

> **PhishShift contributes a reproducible, source-aware evaluation protocol for phishing URL models that separates random-row performance from registrable-domain and source-shift performance, and tests whether explicit lookalike features improve recall at a fixed review budget without hiding false positives.**

This is a scoped research contribution, not a new classifier. The measurable benefit is knowing how much performance survives a more realistic test and whether a modest feature addition provides enough value to justify its false-alert cost. The baseline comparison is a character n-gram model and a compact lexical-feature model; the experiment proving the contribution is the paired random/domain-held-out/source-held-out evaluation on frozen datasets, with identical preprocessing and threshold-selection rules.

If the evidence shows little or no performance drop, or lookalike features do not help, report that outcome. A rigorous negative result is more credible than a fabricated “improvement.” Do not claim results before running the experiment.

What to build and what to defer

Build only: safe URL normalization; exact and near-duplicate detection; registrable-domain grouping; a data manifest with dataset version and label semantics; three baselines; fixed-budget evaluation; an error/explanation card; and a small UI for frozen results. Do not build a universal crawler, live phishing scanner, browser extension, blockchain ledger, federated system, graph neural network, multimodal LLM pipeline or API aggregator in the first iteration.

The evaluation harness is the product core. A clean table of splits and errors, an auditable example card and a replayable run matter more than a broad dashboard. External services such as VirusTotal or Safe Browsing can be displayed as separately attributed context only if terms and access permit; they must not silently define both model input and ground truth.

10. Dataset strategy and evidence inventory

Source or dataset	Availability and access	Label meaning and freshness	Limitations and recommended use
PhishTank	Developer API and downloadable feeds are documented; downloads have application-key/usage requirements. (32)	Community-submitted and verified records; feed entries may describe URLs considered online when generated.	Preserve retrieval, submission and verification time when available. Absence is not benign. Confirm Cisco terms before retaining/redistributing rows.
OpenPhish	Community and academic options are documented; academic access is application-based, limited and time-bounded. (33)	Feed cadence and contents depend on product tier; terms restrict sharing/redistribution.	Optional comparison only after written approval. Do not base the MVP on access that is not granted.
URLhaus	Authenticated Community API and dumps. (34)	Malware-distribution URLs, not phishing generally.	Keep as separate malware scope or exclude; do not silently merge into phishing positives.
UCI Phishing Websites	Public download; donated 2015; 11,055 records and 30 engineered features. (35)	Historical source labels and derived features.	Good parser/model smoke test, poor proxy for contemporary raw-URL deployment; check license/version.
Tranco	Dated, citable popularity lists and methodology are public. (36)	Ranked sites, not independently adjudicated benign domains.	Use as a popularity/reference cohort, labelled “proxy/unlabeled,” never “ground-truth safe.”
Common Crawl	Public indexes and WARC/WAT/WET archives. (37)	Archived crawl observation at a crawl time.	Coverage, crawl and recrawl are selective; not a truth or complete history source. Avoid live page fetching in MVP.

Source or dataset	Availability and access	Label meaning and freshness	Limitations and recommended use
CT logs / CertStream	Public CT protocol/log ecosystem and third-party stream. (13) (14)	Issuance/log observation, not maliciousness. CertStream does not guarantee complete census or service levels.	Defer from PhishShift core; optional future comparative feature. Measure gaps and preserve monitor identity.
Passive DNS	Available through multiple providers, often gated, commercial or partner-restricted. (19) (20) (21)	Provider-vantage observations at query/observation times.	Not required for PhishShift. Do not claim completeness or ownership from shared IP/NS records.
RDAP	Standard query/response protocol. (38)	Current registry/registrar response; optional fields may be missing or redacted.	Not a historical registration log. Optional feature only with retrieval timestamp and missingness.
2024/2025 phishing research datasets	The downloaded 2024 certificate paper and 2025 LegitPhish paper describe datasets; actual dataset version, row-level timestamps and use license require verification before use. (4) (39)	Paper-specific collection and label construction.	Do not assume a historical snapshot or redistribute the data until its record and terms are checked.
CERT-In and public incident reports	Public advisories and incident reports can provide contextual examples.	Advisory date is not the time an attack began.	Use for case discussion or manual validation; not a large machine-learning label set without a formal schema.

Day-two data gate: record the dataset URL, exact release/version, hash, license/terms, fields, label source, sample date and whether a `first_seen`, `submitted`, `verified`, `collection_time` or `registration_time` field exists. If source/date fields are missing, do not call the test “temporal.” If there is only one source, do not call it “cross-source.” Use a domain-grouped test and describe the

result accurately. If the proposed dataset has unclear rights, exclude it and use a documented alternative.

11. Experimental protocol

Cohort, target and splits

Define the prediction unit as one normalized URL observation, but use registrable domain as the grouping unit. Deduplicate exact URLs first, then identify repeated domains and obvious campaign/template duplicates. Keep both raw and normalized forms. Keep IDNA/punycode and Unicode representations as distinct features only where the parser can safely resolve them. Label the positive class by a specific source/status and snapshot; label the comparison cohort as “unlabeled proxy” unless independent adjudication supports “benign.”

Run four comparisons if the data permit. First, a random row split to quantify how easy it is to obtain an optimistic number; do not use it as the main claim. Second, a registrable-domain-grouped split. Third, a source-held-out test if at least two datasets have compatible raw fields and labels. Fourth, a temporal split only when event/collection timestamps are trustworthy. If a given comparison is not supported by the dataset, mark it unavailable rather than inventing a timestamp.

Fit tokenization, feature selection, model parameters, calibration and thresholds on training/validation partitions only. The test set must not influence the threshold. Preserve a split manifest so anyone can reproduce the results.

Baselines and measures

Baseline A: character 2–5 gram TF-IDF with logistic regression on normalized hostname/URL. Baseline B: a small set of interpretable lexical and domain features with a Random Forest or LightGBM. Baseline C: deterministic lookalike candidate generation (such as dnstwist permutations/edit-distance/IDN patterns) with its own precision/recall. An optional hybrid can combine candidate-generation features with the lexical model, but the ablation must show which addition changes results. (12)

Report precision, recall, F1, false-positive rate and PR-AUC. Include the class prevalence, since precision changes with prevalence. Report precision and recall at one predefined operational budget, such as a fixed number of cases an analyst can review per day or per 1,000 observations. Do not choose that limit after inspecting test outcomes. Include calibration with Brier score and reliability plots only when a proper held-out calibration set exists. If using abstention, report coverage and error among accepted cases, plus the number of cases sent to review.

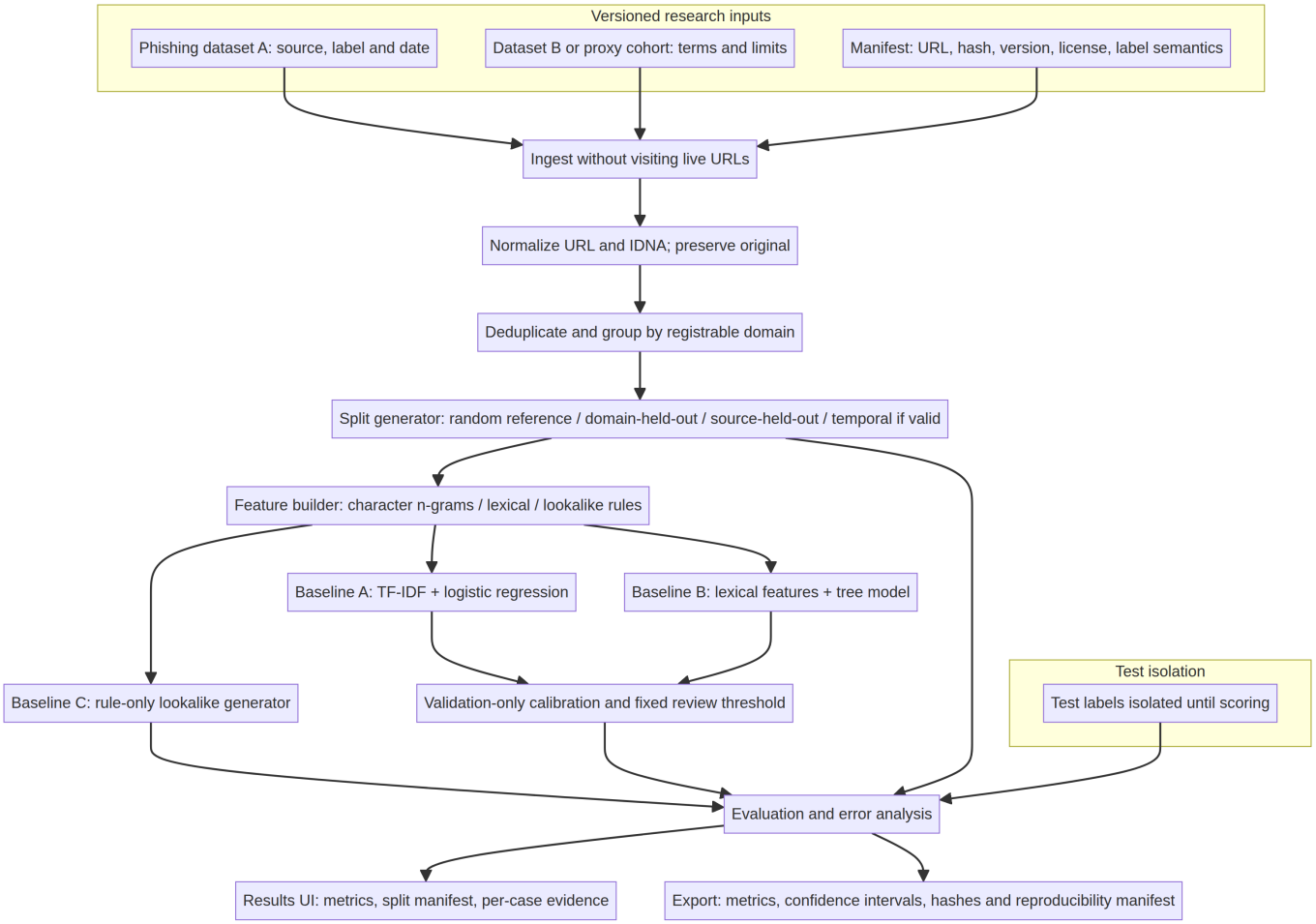
Add source/domain counts and confidence intervals, bootstrapped by domain or campaign rather than correlated URL rows. Run ablations for character features, lexical features, IDN/confusable features and lookalike-candidate features. Review false positives and false negatives by cause: benign lookalike, parked/redirected domain, repeated template, shared hosting, label timing, parse failure, and source mismatch.

Hypotheses, not expected results

- **H1:** a random row split will overstate performance relative to a registrable-domain-held-out test. This is a hypothesis; report the actual difference.
- **H2:** the cross-source test will expose feature/source dependence. The magnitude and direction are unknown.
- **H3:** lookalike/IDN features will improve recall on the targeted lookalike subset at a fixed review budget. This may increase false positives and may not improve overall phishing detection.
- **H4:** a calibration/abstention state will make the system's uncertainty easier to audit, but it may not improve ranking metrics.

A negative result is acceptable. Do not construct a synthetic test set and present it as live performance. Use synthetic URLs only to illustrate parsing and UI behavior, and label them as simulated.

12. Architecture and stack



The selected project uses a frozen-data evaluation pipeline. It does not require CT/DNS ingestion, live page fetching or an event-driven production backend. The manifest preserves dataset version, label provenance and split logic; the test labels remain isolated until scoring.

Component	Why it exists	MVP?	Main technical issue / deferment
Dataset manifests and snapshots	Preserve exact source version, terms and hashes.	Yes	Verify license and field meanings. No raw indicators should be published without rights.
URL normalizer / IDNA parser	Make model inputs reproducible while retaining original strings.	Yes	Parsing edge cases and Unicode are error-prone; record parser version.
Deduplication and domain grouper	Prevent exact/domain leakage across splits.	Yes	Public suffix and campaign grouping are imperfect; document the rules.
Feature builder	Character grams plus small explicit lexical/IDN features.	Yes	Avoid features that encode target source or future information.
Model training	Compare simple baselines to an optional hybrid.	Yes	Prefer interpretable models and fixed data pipeline; no deep net required.
Calibration and review policy	Convert model output into measured probability/abstention or review queue.	Conditional	Only call it calibrated after held-out measurement. Defer if sample size is too small.
Evaluation report	Show metrics by split, source, time and group with error analysis.	Yes	This is the core technical contribution.
Analyst interface	Inspect URL, model evidence and split-specific results.	Thin UI	A Streamlit or simple React view is enough; defer account systems and alerting.
CT/DNS/pDNS enrichment	Add context to a later extension.	No	Data access, coverage, copyright and confounding; only add

Component	Why it exists	MVP?	Main technical issue / deferment
			after a successful data gate.
Monitoring/deployment	Useful after research prototype.	No	Not necessary for a frozen benchmark demo.

Practical stack: Python, pandas or Polars, scikit-learn, an optional LightGBM install, a public-suffix parser, SQLite or Parquet for frozen snapshots, and Streamlit for the demo. Use a lockfile, deterministic random seeds and a one-command run script. Avoid microservices, paid lookup dependencies, full page crawls and front-end overinvestment.

13. MVP implementation plan

Days 1–2: data gate. Confirm exact dataset snapshots, rights, metadata and duplicate/domain fields. If only a single source or no timestamps are available, re-scope the planned test and remove temporal claims. If no permissible data remain, switch to ClaimScope rather than manufacturing a benchmark.

Days 3–4: reproducible data layer. Implement safe URL parsing, IDNA handling, hash manifests, label normalization, exact deduplication, registrable-domain groups and a split manifest. Add tests for malformed URLs, punycode and subdomain cases.

Days 5–6: baselines. Fit character TF-IDF/logistic regression, the compact lexical/tree baseline and the rule-only lookalike generator. Freeze preprocessing and thresholds from training/validation only.

Days 7–8: evaluation. Run random, domain-grouped and source-held-out splits where valid. Compute metrics, fixed-budget curves, calibration if supported, confidence intervals and error samples. Review false alerts and false negatives manually.

Days 9–10: prototype. Build a small view that selects a frozen run, shows how the split was made, displays aggregate comparison and opens an example URL card with a human-readable feature explanation and explicit uncertainty. Do not navigate to the live URL.

Days 11–12: demo hardening. Re-run from a clean environment, freeze the dataset version, export a concise results artifact and rehearse failure-case explanations. Expand only if all primary results are reproducible.

These are estimates for a small team, not a guarantee. Data availability controls the schedule more than model implementation.

14. Two-to-three-minute demonstration

1. **0:00–0:20 — define the failure mode.** Show one static dataset and explain that a random row split can put similar URLs or the same domain on both sides.

2. **0:20–0:50 — show the baseline.** Display one frozen model and the random-split result with its exact sample size and split manifest.
3. **0:50–1:25 — show the strict test.** Switch to registrable-domain/source-held-out results. Show the measured change, including uncertainty and class counts. Do not promise in advance that the score will drop.
4. **1:25–1:55 — show a case.** Open a safe, static, already-labelled URL record. Display original/normalized hostname, top model evidence, lookalike candidate features and label/source time. Never load an active suspicious site.
5. **1:55–2:20 — show the decision tradeoff.** Compare precision and recall at a predeclared review budget; show abstention/coverage only if it was actually implemented and measured.
6. **2:20–2:40 — state limits.** Name the dataset scope, label delay, missing timestamp or proxy-negative limitation. If a scenario is simulated, visibly label it “simulated.”

The technical moment is the comparison between the random split and the held-out split. A project that shows only a score card or a live API call does not demonstrate the research contribution.

15. Risks, judge challenges and answers

Risk or skeptical question	Honest response and mitigation
“Isn’t phishing URL classification common?”	Yes. We do not claim a new classifier. The contribution is a reproducible comparison under source/domain shift and a measured lookalike-feature ablation. Show the protocol and actual results.
“Didn’t CT-plus-passive-DNS detection already exist?”	Yes. RAID 2022 and a direct patent make that a poor novelty claim. That is why CT/pDNS is not the core PhishShift contribution. (1) (18)
“Are the labels true ground truth?”	They are source labels with defined scope and times, not universal truth. We preserve source, status and missingness; we do not treat absence from a feed as benign.
“Does Tranco prove a URL is safe?”	No. It is a popularity proxy. We call it a reference/unlabelled cohort and state the bias. (36)
“Is the detector calibrated?”	Only if a held-out, temporally prior calibration set and proper calibration metrics exist. Otherwise we call the output a model score, not a probability.
“Will it find zero-days?”	This experiment does not establish that. It tests transfer to a held-out dataset/domain or later period. A future unseen threat is an untested claim.
“Why not use VirusTotal?”	It can be a separately attributed comparator if access and terms permit. Engine counts are correlated and do not provide independent ground truth. (28)
“What if the model does not improve?”	Then the result still identifies which claimed gains fail under stronger splits. We will report the null/negative result instead of tuning on the test set.
“What makes the prototype impressive?”	Reproducible splits, domain-leakage audit, model comparisons, an analyst-budget curve, per-error evidence and a clean replay—not infrastructure scale or a generic AI label.
“Could a compromised benign site be flagged?”	Yes. Co-hosting and lookalike features are candidates for review, not proof. The model must show uncertainty and error cases.
“What could cause rejection?”	Weak data rights/provenance, no real held-out test, a demo that overstates labels, or a claim that simply integrates existing APIs. The data gate and limited claim address these risks.

16. Short research agenda and unresolved questions

The team should answer these before finalizing the proposal: (1) Which exact dataset versions include original URLs and usable source or collection times? (2) Can dataset terms permit local modeling, public metric reporting and sample display? (3) How many unique registrable domains remain after deduplication? (4) Are the labels verified phishing, broad maliciousness, or source-specific flags? (5) Can a source-held-out test be built without changing the target label? (6) Can IDNA normalization be applied consistently? (7) Is a calibration split large enough to support calibration claims? (8) What is the intended analyst review budget? (9) How will source/brand overlap be defined? (10) Can the model be replayed from a frozen environment?

Open questions for later work include how to define independent corroboration across feeds; how to account for labels that arrive after site takedown; whether visual evidence adds value after a strong URL baseline under safe collection; how source dependence changes calibration; whether certificate features help on unseen domains; and how far public datasets represent the long tail of benign and malicious sites.

17. Final selection strategy

Which project should the team build? PhishShift, conditional on passing the day-two dataset and license gate. ClaimScope is the fallback if usable URL snapshots or metadata are unavailable. Do not choose TrustPulse solely because it sounds broader.

Why is it stronger than common projects? It does not rely on a single API, browser extension or dashboard as its differentiator. It demonstrates a security claim the judges can inspect: how much a familiar detector’s performance depends on the split, and whether a targeted feature changes a fixed-budget outcome.

What is the exact research contribution? A reproducible source/domain-shift evaluation and lookalike-feature ablation for phishing URL models, with explicit label/source provenance and a predeclared review budget.

What should be built first? The dataset manifest, label audit, URL normalizer and domain-grouped split generator. If these fail, the project premise fails; do not start with the UI.

What should be avoided? Generic multi-API dashboards; an unvalidated “trust score”; declaring feed absence benign; mixing URLhaus malware with phishing; claiming a new classifier; using random-only splits; live malicious-site crawling; and adding pDNS without access terms.

Most important experiment: compare the same frozen baseline and threshold procedure across random, domain-grouped and source-held-out tests. Report sample counts and confidence intervals. This tells the team whether its central claim is supported.

30-second pitch: “PhishShift tests whether phishing URL models actually generalize. We compare simple, reproducible models under random, unseen-domain and source-held-out evaluation, and measure whether lookalike signals improve analyst-useful recall without hiding false positives. The point is not another AI score—it is a trustworthy answer to when that score can be relied on.”

Two-minute technical explanation: “We start with frozen, source-documented phishing URL data and preserve label times and status. We normalize URLs without discarding the original, group duplicate URLs by registrable domain, then compare character n-gram logistic regression, a small lexical-feature tree model and rule-only lookalike generation. We run a random split only as a reference, then domain-grouped and source-held-out evaluation where the data permits it. We select thresholds on validation data at a fixed review budget and report precision, recall, F1, FPR, PR-AUC, calibration if sample size supports it, and error causes. The model never visits live URLs; the UI displays the actual dataset, split, feature evidence and uncertainty. We will report failures or no improvement rather than claim results that the frozen test does not show.”

Minimum implementation that demonstrates genuine technical work: one documented dataset; a working URL normalizer and duplicate/domain splitter; at least two meaningful baselines plus a rule-only lookalike comparator; one valid held-out test; an analyst-budget metric; an error-analysis screen; and a reproducible run manifest. Without the held-out comparison, the central contribution has not been shown.

Appendix A. Relevant paper inventory

Paper	Why it matters	Critical qualification
Drichel et al., *Finding Phish in a Haystack: A Pipeline for Phishing Classification on Certificate Transparency Logs*, ARES 2021. (3)	Establishes CT phishing pipeline, real-time/replay classification and a data/verification workflow.	Feed labels are incomplete/delayed; low-FPR operating point had many false alerts relative to detections; cannot catch every phishing use of benign/compromised certificates.
Meiklejohn et al., *SoK: SCT Auditing in Certificate Transparency*, 2022. (40)	Relevant CT auditing and privacy background.	Not a phishing or malicious-certificate classifier.
Ostertág & Stanek, *Anomaly Detection in Certificate Transparency Logs*, arXiv 2024. (5)	Direct certificate-anomaly prior art.	Isolation Forest anomalies are not malicious labels; qualitative content not fully captured by numeric features.
AlSabah et al., *Content-Agnostic Detection of Phishing Domains using Certificate Transparency and Passive DNS*, RAID 2022. (1)	Closest direct research prior art to generic TrustPulse CT+pDNS early detection.	Study-specific operating point/dataset; label delay, shared hosting and drift matter. The uploaded report's "Phishious" title is inaccurate.
Zieni et al., *Phishing or Not Phishing? A Survey on the Detection of Phishing Websites*, IEEE Access 2023. (41)	Broad taxonomy and dataset/evaluation caveats.	Survey covers a historical literature window; not a 2026 novelty search.
A Systematic Literature Review on Phishing Website Detection, Journal of King Saud University 2023, PDF in the uploaded 2023 batch.	Systematic survey and taxonomy.	The underlying review period is historical and cannot stand in for current prior art.

Paper	Why it matters	Critical qualification
Haraldsdóttir et al., *Unmasking phishers: ML for malicious certificate detection*, Computers & Industrial Engineering 2024. (4)	Certificate/domain/BiLSTM model and explicit five-month time split.	Dataset/label composition and monthly retraining matter; reported F1 is not a global operating result.

Appendix B. Dataset and product inventories

The dataset table in Section 10 covers CT logs/CertStream, PhishTank, OpenPhish, URLhaus, Tranco, Common Crawl, public DNS/pDNS, RDAP, UCI and paper-specific datasets. It explicitly distinguishes actual access method, label meaning, update/collection time, licensing or terms, coverage and intended use. Re-check live terms before collection because feeds and access rules can change.

The commercial and open-source inventory covers Google Safe Browsing/Web Risk, VirusTotal/Google Threat Intelligence, urlscan.io, MISP, OpenCTI, CT monitors, PhishTank/OpenPhish, dnstwist, CertStream and passive-DNS providers. They are documented products/tools, not independently benchmarked competitors. No verified HackMatrix entries are included.

Appendix C. Novelty evidence and exact boundary

Evidence that **supports a useful PhishShift contribution**: a cross-dataset phishing URL study examines feature transfer (11); the survey literature repeatedly warns that dataset composition and feature choice affect outcomes (41); historical URL datasets such as UCI remain widely reused but are not contemporary live corpora (35); dnstwist supplies a transparent candidate-generation baseline (12).

Evidence that **contradicts a new-algorithm claim**: URL phishing classifiers and typosquat generators are established; CT phishing pipelines and CT+pDNS early warning exist (1) (3); certificate phishing models with temporal evaluation exist (4); CT anomaly models exist (5); generic CT+pDNS scoring is close to patent claims (18); provenance and confidence appear in STIX (6); CTI provenance graphs and evidence lineage have prior art (8) (9).

Exact novelty boundary: PhishShift may claim a reproducible evaluation and analyst-facing measurement of source/domain shift and a targeted lookalike-feature ablation on named datasets, only if it implements that experiment and reports the actual outcomes. It may not claim to be the first phishing detector, the first CT early-warning system, the first source-aware intelligence platform, or a reliable detector of future zero-days.

References

[1] **Content-Agnostic Detection of Phishing Domains using Certificate Transparency and Passive DNS.** Open source

[2] **MANTIS: Detection of Zero-Day Malicious Domains Leveraging Low Reputed Hosting Infrastructure.** Open source

[3] **Finding Phish in a Haystack: A Pipeline for Phishing Classification on Certificate Transparency Logs.** Open source

[4] **Unmasking phishers: ML for malicious certificate detection.** Open source

[5] **Anomaly Detection in Certificate Transparency Logs.** Open source

[6] **STIX Version 2.1.** Open source

[7] **Guide to Cyber Threat Information Sharing.** Open source

[8] **Combating Fake Cyber Threat Intelligence using Provenance in Cybersecurity Knowledge Graphs.** Open source

[9] **TRACE-CTI: Auditable Post-Extraction Governance of TTP Claims with Knowledge Graphs.** Open source

[10] **eMudhra intermediate CA key compromise incident record.** Open source

[11] **Can Features for Phishing URL Detection Be Trusted Across Diverse Datasets?.** Open source

[12] **dnstwist domain permutation and lookalike analysis tool.** Open source

[13] **Certificate Transparency Version 2.0.** Open source

[14] **Certificate Transparency in the Wild: Exploring the Reliability of Monitors.** Open source

[15] **EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis.** Open source

[16] **PREDATOR: Proactive Recognition and Elimination of Domain Abuse at Time-Of-Registration.** Open source

[17] **Blocklist-Forecast: Proactive Domain Blocklisting by Identifying Malicious Hosting Infrastructure.** Open source

[18] **Phishing domain detection systems and methods.** Open source

[19] **Passive DNS Real-Time Feed access information.** Open source

[20] **CIRCL Passive DNS service.** Open source

[21] **Rapid7 Sonar data access and use information.** Open source

[22] **Selective Classification for Deep Neural Networks.** Open source

[23] **Evaluating the Effectiveness and Robustness of Visual Similarity-based Phishing Detection Models.** Open source

[24] **Phishpedia implementation and benchmark materials.** Open source

[25] **VisualPhishNet: Zero-Day Phishing Website Detection by Visual Similarity.** Open source

[26] **Analysis and prevention of AI-based phishing email attacks.** Open source

[27] **Google Web Risk threat lists.** Open source

[28] **VirusTotal API v3 overview.** Open source

[29] **urlscan.io API introduction.** Open source

[30] **MISP threat intelligence sharing and analysis platform.** Open source

[31] **OpenCTI graph exploration documentation.** Open source

[32] **PhishTank developer information.** Open source

[33] **OpenPhish academic-use program.** Open source

[34] **URLhaus Community API.** Open source

[35] **UCI Phishing Websites dataset.** Open source

[36] **Tranco research-oriented top sites ranking.** Open source

[37] **Common Crawl access and getting started.** Open source

[38] **Registration Data Access Protocol query format.** Open source

[39] **LegitPhish URL dataset paper.** Open source

[40] **SoK: SCT Auditing in Certificate Transparency.** Open source

[41] **Phishing or Not Phishing? A Survey on the Detection of Phishing Websites.** Open source

[42] **TrustFed-CTI: A Trust-Aware Federated Learning Framework for Privacy-Preserving Cyber Threat Intelligence Sharing.** Open source

[43] **MDN HTTP headers reference.** Open source

[44] **ZLint X.509 certificate linter.** Open source